

IT PROFESSIONAL PORTFOLIO

Cloud Engineering and Security Projects

PROJECT 09

Enforce Organization-Wide Guardrails with Service Control Policies

AWS Organizations | SCPs | Preventive Governance

AUTHOR	Michael Salazar
ENVIRONMENT	Personal AWS Lab
VERSION	v1.0.0
RELEASE DATE	July 10, 2026
STATUS	Complete

Executive Summary

Enabled Service Control Policies (SCPs) in AWS Organizations, created a customer-managed SCP named **ProtectRootAndOrg**, and attached it to the **root of the organization hierarchy**. The policy denies the **organizations:LeaveOrganization** action and denies all actions when the principal ARN matches an AWS account root user.

Business Problem

IAM permissions operate inside individual AWS accounts, but a compromised administrator or root identity could still attempt high-impact actions that threaten organizational governance. Service Control Policies provide preventive guardrails outside member accounts and define the maximum permissions that can be used throughout the organization hierarchy.

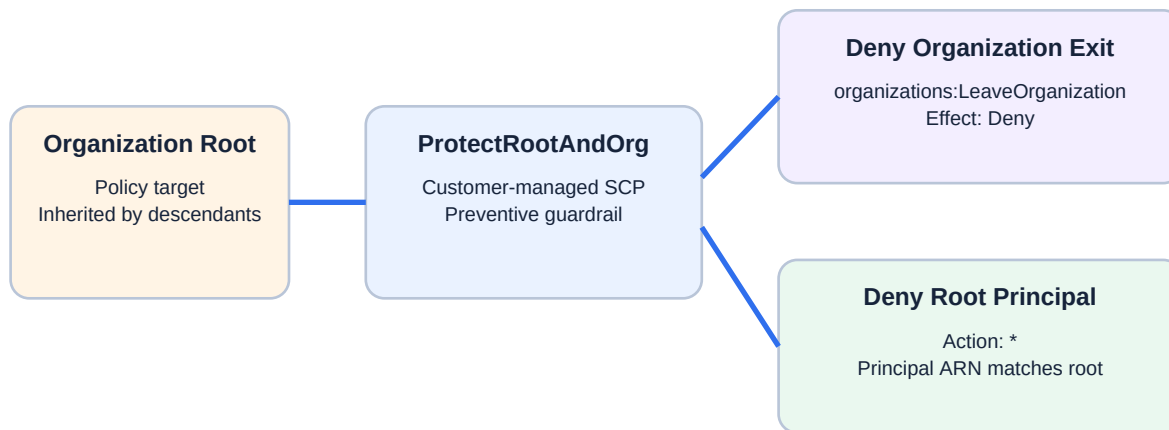
Objectives

- Enable Service Control Policies in AWS Organizations.
- Create a customer-managed SCP named ProtectRootAndOrg.
- Deny the organizations:LeaveOrganization API action.
- Deny all actions performed by root principals in affected member accounts.
- Attach the policy to the organization root so descendant OUs and member accounts inherit the guardrail.
- Preserve the default FullAWSAccess SCP while adding targeted deny statements.

Environment

Cloud Provider	Amazon Web Services (AWS)
Primary Service	AWS Organizations
Policy Type	Service Control Policy (customer-managed)
Policy Name	ProtectRootAndOrg
Attachment Target	Root of the organization hierarchy
Denied Action	organizations:LeaveOrganization
Root Restriction	Deny all actions when aws:PrincipalArn matches arn:aws:iam::*:root
Baseline SCP	FullAWSAccess retained
Purpose	Preventive organization-wide governance guardrail

Architecture



The SCP defines maximum allowed behavior for member accounts under the organization root.
 SCPs do not grant permissions and do not restrict the AWS Organizations management account.

Figure 1 - Organization-root SCP inheritance and deny controls.

Implementation Summary

1. Opened the Policies section of AWS Organizations.
2. Enabled Service Control Policies.
3. Verified that FullAWSAccess remained available as the allow-all baseline.
4. Created the customer-managed ProtectRootAndOrg SCP.
5. Added a Deny statement for organizations:LeaveOrganization.
6. Added a Deny statement for all actions when aws:PrincipalArn matches an account root principal.
7. Attached ProtectRootAndOrg to the root of the organization hierarchy.
8. Validated the policy target and successful attachment.

TERMINOLOGY

The **root of the organization hierarchy** is not the same as an AWS account root user. Attaching the SCP to the organization root causes descendants to inherit it, while the policy's condition specifically targets account root principals.

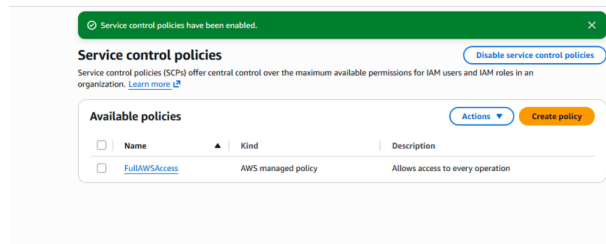
Policy Logic

Statement 1	Deny organizations:LeaveOrganization on all resources

Statement 2	Deny all actions on all resources when aws:PrincipalArn matches arn:aws:iam::*:root
Target	Organization root
Effect on Member Accounts	Inherited preventive guardrail
Effect on Management Account	Not restricted by SCPs

Evidence

Figure 2 - Service Control Policies Enabled



The AWS Organizations console displays the success banner confirming that Service Control Policies were enabled. The FullAWSAccess AWS-managed SCP remains visible as the baseline allow-all policy.

Figure 3 - ProtectRootAndOrg Policy Content

Policy details

Name

ProtectRootAndOrg

ARN

Policy type

Service control policy (customer managed)

Description

Restrict Root account and prevent the ability to leave AWS Organizations

Content

Targets

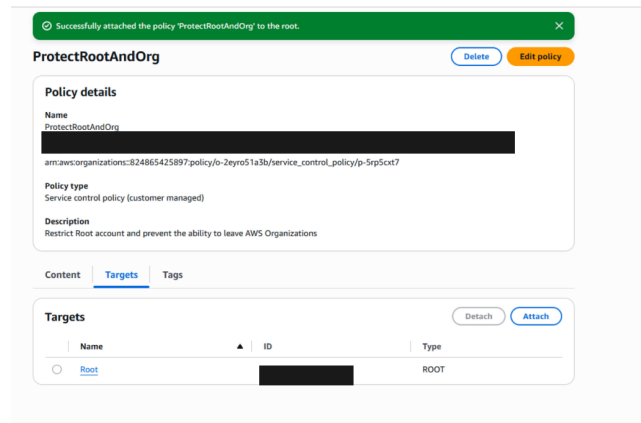
Tags

Content

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Action": [
        "organizations:LeaveOrganization"
      ],
      "Resource": "*",
      "Effect": "Deny"
    },
    {
      "Action": "*",
      "Resource": "*",
      "Effect": "Deny",
      "Condition": {
        "StringLike": {
          "aws:PrincipalArn": [
            "arn:aws:iam::*:root"
          ]
        }
      }
    }
  ]
}
```

The sanitized policy evidence shows the customer-managed ProtectRootAndOrg SCP. Its JSON denies organizations:LeaveOrganization and denies all actions when the aws:PrincipalArn condition matches an account root principal.

Figure 4 - ProtectRootAndOrg Attached to Organization Root



The sanitized target evidence shows the success banner confirming that ProtectRootAndOrg was attached to the root of the organization hierarchy. Sensitive policy and target identifiers were redacted before publication.

Security Analysis

SCPs are preventive guardrails that define the maximum permissions available to identities in affected member accounts. They do not grant permissions by themselves.

Denying organizations:LeaveOrganization helps prevent a member account from removing itself from centralized governance, even if an identity inside that account has broad IAM permissions.

Denying actions from account root principals reduces the impact of root credential compromise in affected member accounts by preventing the root principal from performing AWS API actions.

Attaching the SCP at the organization root gives broad inheritance, so the policy affects descendant OUs and member accounts. This is powerful but increases the importance of policy testing and change control.

The management account is not restricted by SCPs, which is another reason to minimize ordinary workload and administrative activity there.

Lessons Learned

SCPs differ from IAM policies: IAM policies can grant permissions to identities, while SCPs only define the outer boundary of what permissions may be used.

Explicit Deny remains a strong control. Even a highly privileged IAM identity cannot override an applicable SCP deny.

AWS uses the word root in two different contexts: the organization hierarchy root and the root user of an AWS account. Clear terminology is essential when designing and documenting governance controls.

Organization-level controls should be tested carefully because an incorrect SCP can break legitimate activity across multiple accounts.

Production Improvements

- Test SCP changes in a dedicated sandbox or policy-testing OU before broad production rollout.
- Create an incident-response or quarantine OU that supports controlled exceptions and emergency workflows.
- Move broad root-protection policies from the organization root to carefully designed OU layers when the hierarchy becomes more mature.
- Monitor CloudTrail for SCP changes, organization exit attempts, and root-user activity.
- Use change review and version control for SCP JSON documents.
- Document break-glass and policy rollback procedures before deploying additional restrictive guardrails.

Skills Demonstrated

AWS Organizations	Preventive guardrails	Service Control Policies
Organization-root targeting	Root principal restriction	JSON policy analysis
Policy inheritance	Organization exit protection	Explicit deny design

Resume Bullet

RESUME	Implemented organization-wide AWS governance guardrails by enabling Service Control Policies, creating the ProtectRootAndOrg SCP to deny root-principal actions and organization exit attempts, and attaching the policy to the organization root for inherited enforcement.
---------------	--

STAR Interview Story

Situation: The multi-account AWS environment needed preventive controls that could not be bypassed by administrators inside member accounts.

Task: Create an organization-level guardrail that protected account membership and restricted use of account root principals.

Action: I enabled SCPs, created ProtectRootAndOrg with explicit denies for organizations:LeaveOrganization and root-principal activity, attached it to the organization root, and validated successful inheritance targeting.

Result: The organization now has a centrally managed preventive control that limits high-risk actions across descendant member accounts and strengthens governance beyond individual IAM permissions.

Version History

v1.0.0	July 10, 2026	Initial documented implementation. Enabled Service Control Policies, created the ProtectRootAndOrg customer-managed SCP, denied organization exit and root-principal activity, attached the policy to the organization root, sanitized sensitive identifiers, and embedded all provided project evidence using portfolio documentation standard v1.0.1.

References

- Cloud Security Lab a Week (S.L.A.W.) - Give Your Account a Security Blanket with SCPs.
- User-provided Service Control Policies enabled screenshot.
- User-provided ProtectRootAndOrg policy content screenshot.
- User-provided policy attachment to organization root screenshot.
- Project 08 - AWS Organizations Security OU and SecurityAudit Account.